AIGP Module 4: Governing AI Development

Comprehensive Study Notes

---

1. INTRODUCTION TO GOVERNING AI DEVELOPMENT

1.1 Purpose of Module 4

This module focuses on governance throughout the AI development lifecycle—from initial planning through testing and pre-deployment validation. It covers the technical and organizational practices needed to build AI systems responsibly.

Key Focus Areas:

- AI development lifecycle stages (Plan, Design, Develop, Implement)
- Business context and impact assessments
- Data governance for AI
- Model development and selection
- Training, testing, and validation requirements
- Human oversight mechanisms (Three Lines of Defense)
- AI-specific security threats
- Documentation and operational controls
- Pre-deployment validation

Relationship to Other Modules:

- Builds on governance structures from Module 3
- Implements responsible AI principles from Module 2
- Precedes deployment governance in Module 5

---

2. AI DEVELOPMENT LIFECYCLE

2.1 Overview of Lifecycle Stages

The AI development lifecycle consists of four main phases:

1. **PLAN**: Define business context, assess impacts, engage stakeholders
2. **DESIGN**: Design system architecture, select models, plan data strategy
3. **DEVELOP**: Build and train models, implement features, test rigorously
4. **IMPLEMENT**: Pre-deployment validation, pilot testing, deployment preparation

Narahari

Governance Integration: Each stage has specific governance activities, checkpoints, and requirements.

---

3. PHASE 1: PLAN

3.1 Defining Business Context

Purpose: Establish clear understanding of why AI is needed and what it should accomplish.

Key Questions:

- What business problem are we solving?
- Why is AI the appropriate solution?
- What are the expected benefits and outcomes?
- What are success criteria?
- What resources are available?
- What are the constraints and limitations?

Business Case Elements:

- Problem definition and scope
- Proposed AI solution
- Expected benefits (quantitative and qualitative)
- Costs and resource requirements
- Timeline and milestones
- Risks and mitigation strategies
- Alignment with organizational strategy
- Return on investment (ROI) analysis

Governance Checkpoint: Initial approval to proceed with AI development

---

3.2 Impact Assessments

Conduct appropriate impact assessments during planning phase:

Algorithmic Impact Assessment (AIA):

Purpose: Comprehensive evaluation of AI system's potential impacts

When: Early in planning, before significant investment

Content:

Narahari

- Intended purpose and use cases
- Affected populations and stakeholders
- Potential benefits and positive impacts
- Potential harms and negative impacts
- Severity and likelihood of impacts
- Alternatives considered
- Mitigation strategies
- Ongoing monitoring plans

Process:

1. Define scope and use case
2. Identify stakeholders and affected parties
3. Assess potential impacts (positive and negative)
4. Evaluate magnitude and probability
5. Propose mitigation measures
6. Document findings and decisions
7. Review and approve
8. Update throughout lifecycle

Data Protection Impact Assessment (DPIA):

Purpose: Assess privacy risks from personal data processing

When Required: GDPR Article 35 requires DPIA for high-risk processing:

- Systematic and extensive profiling with significant effects
- Large-scale processing of special category data
- Systematic monitoring of publicly accessible areas

Content:

- Description of processing operations and purposes
- Assessment of necessity and proportionality
- Legal basis for processing
- Assessment of risks to data subject rights
- Measures to address risks
- Safeguards and security measures

Narahari

- Data retention and deletion

Process:

1. Describe processing and context
2. Assess necessity and proportionality
3. Identify and assess privacy risks
4. Identify measures to mitigate risks
5. Consult with Data Protection Officer
6. Seek views of data subjects (where appropriate)
7. Document assessment
8. Review and approve
9. Consult supervisory authority if high residual risk

Governance Integration: DPIA required before processing begins; must be approved by DPO

Privacy Impact Assessment (PIA):

Purpose: Similar to DPIA but broader privacy assessment framework (not limited to GDPR context)

Use: Organizations may conduct PIA even when DPIA not legally required

Scope: All privacy implications, not just personal data processing

---

Other Context-Specific Assessments:

- **Human Rights Impact Assessment**: For systems affecting fundamental rights
- **Environmental Impact Assessment**: For high-energy AI systems
- **Bias Impact Assessment**: Specifically focused on fairness risks
- **Safety Assessment**: For systems with physical safety implications

---

3.3 Stakeholder Engagement

Early Engagement Critical: Stakeholders should be involved from planning phase

Internal Stakeholders:

- Business owners and sponsors
- End users within organization
- IT and infrastructure teams

Narahari

- Legal, compliance, privacy, security
- Risk management
- Ethics committee or governance board

External Stakeholders:

- Customers and end users
- Affected individuals and communities
- Subject matter experts
- Regulators (where appropriate)
- Civil society organizations
- Academic partners

Engagement Methods:

- Workshops and consultations
- User research and interviews
- Surveys and feedback
- Advisory committees
- Public consultations
- Co-design sessions

Documentation:

- Who was engaged and when
- What input was received
- How input influenced design
- Decisions made and rationale
- Ongoing engagement plans

3.4 Operational Controls

Definition: Mechanisms and safeguards to manage AI operation and mitigate risks

Examples from Planning Phase:

Use Case Boundaries:

- Clear definition of intended use
- Explicit out-of-scope uses
- User guidance on appropriate use

Narahari

Human Oversight Requirements:

- Level of human involvement needed (in-loop, on-loop, out-of-loop)
- Who provides oversight and their qualifications
- Escalation procedures

Kill Switch / Emergency Stop:

- Capability to immediately halt AI system
- Clear triggers for activation
- Authorized personnel
- Procedures for shutdown and restart

Access Controls:

- Who can use, modify, or access AI system
- Authentication and authorization
- Audit logging

Monitoring and Alerting:

- What metrics to track
- Alert thresholds
- Response procedures

Incident Response:

- Definition of incidents for this system
- Reporting channels
- Investigation procedures
- Remediation plans

Governance Checkpoint: Operational controls plan approved before proceeding to design

---

4. PHASE 2: DESIGN

4.1 System Architecture Design

Components:

- Data pipelines and storage
- Model architecture and infrastructure
- Integration with existing systems
- User interfaces and APIs

Narahari

- Monitoring and logging systems
- Security and access controls

Design Principles:

- **Privacy by Design**: Embed privacy protections from the start
- **Security by Design**: Build in security, don't add later
- **Fairness by Design**: Proactively address bias risks
- **Transparency by Design**: Enable explainability and auditability
- **Safety by Design**: Anticipate failure modes and safeguards

Governance Considerations:

- Alignment with organizational standards
- Compliance with regulatory requirements
- Scalability and maintainability
- Auditability and traceability
- Resilience and redundancy

4.2 Model Selection

Considerations:

Performance Requirements:

- Accuracy, precision, recall needs
- Latency and throughput requirements
- Computational constraints
- Scalability needs

Interpretability vs. Accuracy Tradeoff:

- High-stakes decisions may require interpretable models
- Lower-risk applications can use complex "black box" models
- Balance based on risk assessment and use case

Model Types:

- **Traditional ML**: Decision trees, random forests, SVMs, logistic regression
- **Deep Learning**: Neural networks, CNNs, RNNs, transformers
- **Generative AI**: GANs, VAEs, large language models
- **Ensemble Methods**: Combining multiple models

Narahari

Proprietary vs. Open Source:

- **Proprietary**: Professional support, potentially higher quality, less transparent, vendor dependency, cost
- **Open Source**: Transparency, customizability, community support, variable quality, security concerns

Pre-trained vs. Custom:

- **Pre-trained (Foundation Models)**: Faster development, lower cost, less control, potential bias from training data
- **Custom-Built**: Full control, optimized for use case, higher cost, longer timeline

Governance Checkpoint: Model selection rationale documented and approved

---

4.3 Metric Evaluation and Selection

Performance Metrics:

Classification Tasks:

- **Accuracy**: Overall correctness (correct predictions / total predictions)
- **Precision**: Of positive predictions, how many correct (true positives / [true positives + false positives])
- **Recall (Sensitivity)**: Of actual positives, how many identified (true positives / [true positives + false negatives])
- **F1 Score**: Harmonic mean of precision and recall
- **ROC-AUC**: Area under receiver operating characteristic curve

Regression Tasks:

- **Mean Absolute Error (MAE)**
- **Mean Squared Error (MSE)**
- **Root Mean Squared Error (RMSE)**
- **R-squared**: Proportion of variance explained

Fairness Metrics:

- **Demographic Parity**: Equal positive prediction rates across groups
- **Equalized Odds**: Equal true positive and false positive rates across groups
- **Predictive Parity**: Equal positive predictive value across groups
- **Individual Fairness**: Similar individuals receive similar predictions

Fairness Tradeoffs:

- Different fairness definitions can be mathematically incompatible

Narahari

- Must choose appropriate fairness criterion based on context
- May involve accuracy-fairness tradeoffs
- Document decisions and rationale

Other Metrics:

- **Latency**: Time to generate prediction
- **Throughput**: Predictions per second
- **Robustness**: Performance under perturbations
- **Calibration**: Confidence scores match actual accuracy
- **Coverage**: Proportion of cases system can handle

Metric Selection Considerations:

- Align with business objectives
- Reflect stakeholder values
- Consider context (e.g., medical diagnosis: high recall critical to not miss diseases)
- Document tradeoffs and decisions

---

5. PHASE 3: DEVELOP

5.1 Data Governance for AI

Critical Importance: "Garbage in, garbage out"—data quality determines AI quality

---

5.1.1 Data Collection

Sources:

- Internal databases and systems
- User-generated data
- Sensors and IoT devices
- Public datasets
- Third-party data providers
- Web scraping
- Synthetic data generation

Quality Criteria:

- **Accuracy**: Correct and truthful
- **Completeness**: All necessary data present

Narahari

- **Consistency**: Uniform across sources
- **Timeliness**: Current and up-to-date
- **Relevance**: Appropriate for intended use

Legal and Ethical Considerations:

- **Legal basis**: Consent, contract, legal obligation, legitimate interest, etc. (GDPR Article 6)
- **Notice and transparency**: Inform data subjects about collection and use
- **Consent**: Obtain when required, must be freely given, specific, informed, unambiguous
- **Data minimization**: Collect only what's necessary
- **Purpose limitation**: Use only for stated purposes
- **Special category data**: Extra protections for sensitive data (GDPR Article 9)

Documentation:

- Data sources and provenance
- Collection methods and dates
- Legal basis and consent
- Data characteristics and limitations
- Known biases or gaps

5.1.2 Data Quality

Quality Dimensions:

Accuracy:

- Correctness of data values
- Validation against ground truth
- Error detection and correction

Completeness:

- Missing values identified and addressed
- Coverage of relevant populations and scenarios
- Gaps documented

Consistency:

- Uniform formatting and encoding
- Reconciliation across sources

Narahari

- Handling conflicting data

Timeliness:

- Currency of data
- Update frequency
- Obsolete data removed

Representativeness:

- Reflects target population
- Balanced across relevant characteristics
- Addresses sampling bias

Quality Assurance Process:

1. Data profiling and assessment
2. Identify quality issues
3. Clean and preprocess
4. Validate improvements
5. Document quality metrics
6. Ongoing monitoring

Governance: Data quality standards and validation procedures required

---

5.1.3 Data Lineage and Provenance

Data Lineage:

Definition: Complete history of data from origin through transformations to current state

Why Important:

- Traceability for audits
- Understanding data transformations
- Impact analysis (if source changes, what's affected)
- Debugging and troubleshooting
- Compliance demonstration
- Reproducibility

Information to Track:

- Original data sources
- Collection date and method

Narahari

- Transformations and preprocessing steps
- Versions and updates
- Access and usage history
- Quality assessments

Implementation:

- Automated lineage tracking tools
- Metadata management systems
- Documentation standards
- Version control

Data Provenance:

Definition: Origin and custody chain of data

Overlaps with Lineage: Both track data history, provenance focuses on origin and authenticity

Importance:

- Verify data authenticity
- Assess trustworthiness
- Legal compliance (data rights, licensing)
- Academic and scientific integrity

5.1.4 Data Wrangling and the Five V's

Data Wrangling: Process of cleaning, structuring, and enriching raw data into desired format for analysis

Steps:

1. **Discovery**: Understand data structure and content
2. **Structuring**: Organize into usable format
3. **Cleaning**: Fix errors, handle missing values, remove duplicates
4. **Enriching**: Augment with additional data
5. **Validating**: Verify quality and consistency
6. **Publishing**: Make available for use

The Five V's of Big Data (revisited in AI development context):

Narahari

1. Volume:

- **Challenge**: Managing massive datasets (terabytes to petabytes)
- **AI Implications**:
  - Storage costs and infrastructure
  - Processing time for training
  - Privacy risks from large-scale data
- **Governance**: Data retention policies, storage security, access controls

2. Velocity:

- **Challenge**: High-speed data generation and processing needs
- **AI Implications**:
  - Real-time or near-real-time AI requirements
  - Streaming data pipelines
  - Continuous learning systems
- **Governance**: Data quality in streaming contexts, consent for real-time use

3. Variety:

- **Challenge**: Diverse data types (structured, semi-structured, unstructured)
- **AI Implications**:
  - Integration of multiple data sources
  - Multimodal AI systems
  - Complex preprocessing needs
- **Governance**: Consistent handling across types, unified privacy protections

4. Veracity:

- **Challenge**: Trustworthiness, accuracy, and quality of data
- **AI Implications**:
  - Bias and errors in training data
  - Uncertainty and noise
  - Data quality directly affects AI quality
- **Governance**: Data validation, quality assurance, provenance tracking

5. Value:

- **Challenge**: Extracting actionable insights from data
- **AI Implications**:

Narahari

    - Ensuring AI creates value from data
    - ROI considerations
    - Balancing costs and benefits
- **Governance**: Purpose limitation, data minimization, value assessment

---

5.1.5 Privacy-Enhancing Technologies (PETs) in Development

Application During Development:

Differential Privacy:

- Add noise during training to protect individual privacy
- Privacy budget management
- Tradeoff with model accuracy

Federated Learning:

- Train on decentralized data without centralizing
- Preserves data locality
- Reduces privacy risks

Homomorphic Encryption:

- Compute on encrypted data
- Enables privacy-preserving outsourced training
- High computational cost

Secure Multi-Party Computation:

- Multiple parties jointly compute without revealing individual inputs
- Collaborative AI development with privacy

De-identification:

- Anonymization or pseudonymization of training data
- Risk of re-identification must be assessed
- GDPR: pseudonymized data still personal data

Synthetic Data:

- Generate artificial data resembling real data
- Preserves statistical properties while protecting individuals
- Risk of information leakage must be evaluated

Governance: Assess and implement appropriate PETs based on privacy risks

Narahari

5.1.6 Feature Engineering

Definition: Process of selecting, creating, and transforming input variables (features) for machine learning models

Purpose:

- Improve model performance
- Make patterns more apparent
- Reduce dimensionality
- Encode domain knowledge

Activities:

- **Feature Selection**: Choose relevant features, remove irrelevant/redundant
- **Feature Creation**: Derive new features from existing (e.g., age from birthdate)
- **Feature Transformation**: Scale, normalize, encode categorical variables
- **Feature Extraction**: Reduce dimensionality (e.g., PCA)

Governance Considerations:

Bias Risks:

- Features may correlate with protected characteristics (proxies)
- Historical bias embedded in features
- Feature engineering choices reflect developer assumptions

Transparency:

- Document feature engineering decisions
- Explain derived features
- Enable interpretability

Consistency:

- Features must be computed consistently in training and deployment
- Version control for feature definitions
- Automated feature pipelines reduce errors

Fairness:

- Evaluate features for discriminatory potential
- Test for proxy discrimination
- Consider fairness implications of feature choices

Narahari

Documentation:

- Feature definitions and rationale
- Transformation methods
- Dependencies and assumptions
- Known limitations

5.2 Model Training

Process:

1. Split data (training, validation, test sets)
2. Initialize model with architecture and hyperparameters
3. Train model on training data
4. Tune hyperparameters using validation data
5. Evaluate on test data
6. Iterate if performance insufficient

Training Data Requirements:

- Sufficient quantity for learning
- Diversity and representativeness
- Quality and accuracy
- Relevance to deployment context
- Balanced classes (or intentional imbalance addressed)

Hyperparameter Tuning:

- Learning rate, batch size, number of layers, etc.
- Systematic search (grid search, random search, Bayesian optimization)
- Avoid overfitting to validation set

Governance Considerations:

- Document training process and parameters
- Version control for models and data
- Reproducibility requirements
- Resource usage (energy, compute time)

5.3 Training, Testing, and Validation

Narahari

Critical Phase: Rigorous testing essential before deployment

5.3.1 Accuracy Testing

Purpose: Verify model performs as intended on unseen data

Methods:

- Holdout test set (not used in training or validation)
- Cross-validation
- Comparison with baseline models
- Evaluation on multiple metrics

Considerations:

- Test data must be representative of deployment context
- Beware of data leakage (test data influencing training)
- Document performance across different scenarios

5.3.2 Robustness and Reliability Testing

Robustness:

Definition: Model's ability to maintain performance under variations and perturbations

Testing Methods:

- Input variations (noise, missing values, outliers)
- Edge cases and boundary conditions
- Stress testing (extreme inputs)
- Real-world data variability

Goals:

- Identify brittle behaviors
- Ensure graceful degradation
- Validate performance beyond ideal conditions

Reliability:

Definition: Consistency and dependability of model over time and across contexts

Testing Methods:

- Repeated predictions for same input

Narahari

- Performance across different subpopulations
- Temporal consistency
- Different deployment environments

Goals:

- Consistent performance
- Minimal unexpected behaviors
- Dependability for operational use

Brittleness:

Definition: AI system's fragility and sensitivity to small changes in inputs or context

Characteristics:

- Minor input changes cause dramatic output changes
- Poor performance on slightly different data distribution
- Inability to generalize beyond training conditions
- Unexpected failures in real-world use

Testing:

- Adversarial examples
- Out-of-distribution data
- Edge cases
- Real-world scenarios

Mitigation:

- Robust training techniques
- Diverse training data
- Regularization
- Ensemble methods
- Comprehensive testing

5.3.3 Privacy Testing

Purpose: Verify privacy protections are effective

Methods:

Privacy Budget Verification (for differential privacy):

Narahari

- Confirm noise addition is correct
- Validate epsilon (privacy parameter) choice
- Test cumulative privacy loss

Re-identification Testing:

- Attempt to re-identify individuals from anonymized data
- Linkage attacks with external data
- Assess re-identification risk

Model Inversion Testing:

- Attempt to reconstruct training data from model
- Membership inference attacks (determine if specific data was in training set)
- Attribute inference attacks

PET Effectiveness:

- Validate federated learning doesn't leak information
- Confirm homomorphic encryption correctness
- Test synthetic data utility vs. privacy tradeoff

Governance: Privacy testing results documented and approved by DPO

5.3.4 Interpretability Testing

Purpose: Verify model can be explained adequately for use case

Testing Methods:

Global Interpretability:

- Feature importance analysis
- Model structure understanding
- Overall behavior patterns

Local Interpretability:

- Explanation for individual predictions
- LIME, SHAP, or similar techniques
- Counterfactual explanations

Explanation Quality:

- Fidelity (how accurately explanations represent model)
- Consistency (similar inputs get similar explanations)

Narahari

- Understandability (stakeholders can comprehend)
- Actionability (users can act on explanations)

User Testing:

- Present explanations to actual users
- Assess comprehension and usefulness
- Iterate based on feedback

Governance: Interpretability requirements based on risk level and regulatory requirements

---

5.3.5 Safety Testing

Purpose: Verify AI system doesn't cause harm

Testing Methods:

Failure Mode Analysis:

- Identify ways system could fail
- Assess consequences of each failure
- Test safeguards

Safety Scenario Testing:

- High-risk scenarios
- Emergency situations
- System limits and boundaries

Harm Assessment:

- Physical safety (autonomous systems, medical AI)
- Psychological safety (avoid manipulative or harmful content)
- Societal safety (disinformation, radicalization risks)

Safeguard Validation:

- Test kill switches and emergency stops
- Verify human override capabilities
- Validate monitoring and alerting

Real-World Simulation:

- Test in realistic conditions
- Pilot in controlled environments
- Progressive rollout

Narahari

Governance: Safety validation required before deployment, especially for high-risk systems

---

5.3.6 Bias and Fairness Testing

Purpose: Identify and mitigate discriminatory bias

Testing Methods:

Disaggregated Performance Analysis:

- Break down metrics by demographic groups
- Compare error rates, precision, recall across groups
- Identify disparities

Fairness Metric Evaluation:

- Test against chosen fairness metrics (demographic parity, equalized odds, etc.)
- Document tradeoffs
- Assess acceptability of any disparities

Intersectional Analysis:

- Test across combinations of characteristics (e.g., race + gender)
- Identify compounding disadvantages

Scenario-Based Testing:

- Test with specific cases designed to reveal bias
- Representative examples from different groups

Bias Audit Process:

1. Define protected characteristics and groups
2. Obtain or generate test data covering groups
3. Measure performance disaggregated by groups
4. Compare against fairness thresholds
5. Investigate disparities
6. Mitigate identified biases
7. Re-test after mitigation
8. Document findings and actions

Challenges:

- Limited demographic data for testing (privacy constraints)
- Use of proxies or synthetic data

Narahari

- Defining appropriate fairness standard
- Tradeoffs between fairness and accuracy

Governance: Bias testing mandatory for high-risk AI, results reviewed by ethics committee

---

5.3.7 Repeatability Testing

Purpose: Verify consistent results across repeated runs

Importance:

- Scientific validity
- Reproducibility for audits
- Trust and credibility
- Debugging and troubleshooting

Testing Methods:

- Multiple training runs with same data and parameters
- Assess variance in results
- Set random seeds for deterministic behavior
- Document non-deterministic elements

Documentation:

- Training procedures
- Hyperparameters and random seeds
- Data versions
- Software and library versions
- Hardware specifications

Governance: Reproducibility requirements especially important for regulated sectors

---

5.3.8 Adversarial Testing

Purpose: Test resilience against malicious attacks

Attack Types:

Evasion Attacks:

- Craft inputs to fool model
- Imperceptible perturbations causing misclassification
- Test with adversarial examples

Narahari

Poisoning Attacks:

- Simulate data poisoning during training
- Test model's robustness to corrupted data
- Validate data validation mechanisms

Model Extraction:

- Attempt to steal model through queries
- Test query rate limiting and protections

Model Inversion:

- Attempt to reconstruct training data
- Test privacy protections

Methods:

- Red teaming (adversarial experts attempt attacks)
- Automated adversarial example generation
- Penetration testing
- Bug bounties (external security researchers)

Mitigation Validation:

- Test adversarial training effectiveness
- Validate input validation and sanitization
- Confirm monitoring and detection systems

Governance: Adversarial testing especially important for security-critical applications

---

5.4 Three Lines of Defense Model

Origin: Framework from enterprise risk management, adapted for AI governance

Purpose: Structured approach to oversight and accountability with clear separation of duties

---

5.4.1 First Line of Defense: Management Controls

Who: Operational management and AI developers/deployers

Responsibilities:

- **Own and manage risks**: Direct responsibility for AI development and operation
- **Implement controls**: Build in safeguards, follow policies
- **Day-to-day risk management**: Ongoing monitoring and issue resolution

Narahari

- **Primary accountability**: Responsible for AI outcomes

Activities:

- Develop AI systems following governance policies
- Conduct initial testing and validation
- Implement operational controls
- Monitor performance and address issues
- Document development process
- Report risks and incidents

Key Principle: Those building and operating AI have first responsibility for doing it right

---

5.4.2 Second Line of Defense: Oversight Functions

Who: Compliance, risk management, legal, privacy, security, AI ethics committee

Responsibilities:

- **Oversight and challenge**: Independent review of first line activities
- **Policy and standards**: Develop governance frameworks
- **Guidance and support**: Help first line meet requirements
- **Risk monitoring**: Track AI risks across organization
- **Escalation**: Raise significant issues to leadership

Activities:

- Review AI systems for compliance
- Conduct or oversee impact assessments
- Provide guidance on policies and best practices
- Monitor risk indicators
- Challenge decisions and require improvements
- Report to leadership on AI governance

Key Principle: Independent oversight and effective challenge

Effective Challenge:

Definition: Ability and responsibility of second line to question, scrutinize, and require changes to first line's work

Characteristics:

Narahari

- **Independence**: No conflict of interest, separate reporting lines
- **Expertise**: Sufficient knowledge to evaluate AI decisions
- **Authority**: Power to require changes or escalate
- **Resources**: Time and tools to conduct thorough reviews

Importance:

- Prevents "rubber-stamping"
- Identifies issues first line may miss
- Ensures policies are followed
- Protects organization from risks

Implementation:

- Clear escalation procedures
- Authority to stop deployment if concerns unresolved
- Direct access to senior leadership
- Protection from retaliation for raising concerns

5.4.3 Third Line of Defense: Internal Audit

Who: Internal audit function

Responsibilities:

- **Independent assurance**: Objective assessment of AI governance effectiveness
- **Audit of first and second lines**: Evaluate both operational and oversight functions
- **Report to highest governance levels**: Board audit committee
- **Recommendations for improvement**: Systematic enhancement of governance

Activities:

- Audit AI development processes
- Assess compliance with policies
- Evaluate effectiveness of controls
- Review risk management processes
- Test effectiveness of second line oversight
- Report findings to board and leadership
- Follow up on remediation

Key Principle: Independent, objective assurance to the board

Narahari

Characteristics:

- Fully independent (reports to board audit committee)
- Comprehensive scope (all AI activities)
- Risk-based audit planning
- Professional audit standards

5.4.4 Benefits of Three Lines Model

Clear Accountability: Everyone knows their role and responsibilities

Separation of Duties: Prevents conflicts of interest

Layered Protection: Multiple checkpoints reduce risk of issues slipping through

Independent Oversight: Second and third lines provide objective assessment

Structured Escalation: Clear path for raising and resolving issues

Best Practice: Widely recognized risk management framework

---

6. RISK MITIGATION HIERARCHY

Framework: Structured approach to risk treatment, prioritizing more effective strategies

Order of Preference (most to least preferable):

6.1 Level 1: AVOID

Definition: Eliminate the risk by not using AI for this use case

When Appropriate:

- Risks too high to mitigate acceptably
- No viable mitigation strategies
- Alternatives available that don't pose risks
- Legal or ethical concerns too significant

Examples:

- Deciding not to use AI for high-stakes decisions without human oversight
- Abandoning use case after impact assessment reveals unacceptable harms
- Choosing non-AI solution when AI risks outweigh benefits

Governance: Requires senior management approval and documentation of decision

---

Narahari

6.2 Level 2: MINIMIZE (Mitigate)

Definition: Reduce likelihood or severity of risks through safeguards and controls

When Appropriate:

- Risks can be reduced to acceptable levels
- AI provides significant benefits
- Mitigation strategies are feasible

Technical Mitigation Examples:

- Bias mitigation techniques (reweighting, adversarial debiasing)
- Privacy-enhancing technologies
- Adversarial training for robustness
- Ensemble methods for reliability
- Input validation and sanitization

Organizational Mitigation Examples:

- Human-in-the-loop for high-stakes decisions
- Enhanced monitoring and alerting
- Training and competency requirements
- Phased rollout with monitoring
- Clear policies and procedures

Governance: Most common risk treatment; requires documentation of mitigation measures and validation of effectiveness

---

6.3 Level 3: REMEDIATE

Definition: Have plans to address harm if it occurs

Components:

Incident Response:

- Detection and alert mechanisms
- Investigation procedures
- Immediate containment (e.g., disable system)

Remediation:

- Fix underlying issue
- Compensate affected individuals

Narahari

- Correct erroneous decisions
- Update system to prevent recurrence

Communication:

- Notify affected parties
- Report to regulators (if required)
- Public disclosure (when appropriate)
- Transparency about what happened and fixes

Learning:

- Root cause analysis
- Update policies and procedures
- Share lessons learned
- Prevent similar issues

Preparedness:

- Incident response plans
- Resources ready
- Trained personnel
- Pre-established communication channels

Governance: Incident response plan required for all AI systems, especially high-risk

---

6.4 Level 4: OFFSET

Definition: Take compensating actions to balance harms

Examples:

- Carbon offsets for energy-intensive AI training
- Investments in affected communities
- Funding for digital literacy and access
- Support for workers displaced by AI

Limitations:

- Doesn't prevent harm
- May not fully compensate
- Can be seen as "buying the right to harm"
- Less preferable than preventing harm

Narahari

Governance: Should not replace prevention; document justification for accepting residual harms

---

6.5 Applying the Hierarchy

Best Practice: Work down the hierarchy

1. First, can risk be avoided?
2. If not, can it be minimized to acceptable level?
3. Ensure remediation plans in place for residual risks
4. Consider offsets only as last resort

Documentation: Explain which strategies applied and why, especially if choosing lower levels when higher-level mitigation possible

---

7. AI-SPECIFIC SECURITY THREATS (Detailed)

Covered in Module 2, but deeper technical context for development:

7.1 Model Inversion Attacks

Technical Details:

- Attacker has query access to model
- Sends carefully crafted inputs
- Analyzes outputs to infer training data properties
- Can reconstruct sensitive information about training data

Defense Mechanisms:

- Differential privacy during training (adds noise)
- Query rate limiting
- Output perturbation (add noise to predictions)
- Access controls and authentication
- Monitoring for suspicious query patterns

Development Phase Actions:

- Implement differential privacy
- Design query monitoring systems
- Test privacy guarantees
- Document privacy risks

Narahari

7.2 Model Extraction (Model Stealing)

Technical Details:

- Attacker queries model extensively
- Trains surrogate model on input-output pairs
- Creates functional copy of proprietary model

Defense Mechanisms:

- Query rate limiting and monitoring
- Watermarking model outputs (embed signals that survive extraction)
- Detection of extraction attempts (unusual query patterns)
- Legal protections (terms of service, IP law)
- Obfuscation of model outputs

Development Phase Actions:

- Implement query monitoring
- Consider watermarking techniques
- Design access controls
- Plan detection strategies

7.3 Data Poisoning Attacks

Technical Details:

Types:

- **Availability attacks**: Reduce overall model performance through mislabeled data
- **Backdoor attacks**: Inject trigger pattern that causes specific misbehavior

Example Backdoor Attack:

- Attacker adds images with specific pattern (e.g., small sticker) labeled with target class
- Model learns: pattern → target class
- Deployed model classifies any image with pattern as target class
- Attacker can manipulate predictions by adding pattern

Defense Mechanisms:

- **Data validation and sanitization**: Detect anomalies in training data
- **Robust training methods**: Training techniques resistant to outliers
- **Data provenance**: Track and verify data sources

Narahari

- **Anomaly detection**: Identify suspicious data points
- **Ensemble methods**: Multiple models harder to poison consistently

Development Phase Actions:

- Implement data validation pipelines
- Use trusted data sources
- Monitor data quality
- Test model against poisoned data
- Document data provenance

7.4 Adversarial Evasion Attacks

Technical Details:

How They Work:

- Small, often imperceptible perturbations to inputs
- Exploit model's learned decision boundaries
- Cause confident misclassification

Example:

- Image classifier correctly identifies "panda"
- Add imperceptible noise: human still sees panda
- Model confidently misclassifies as "gibbon"

Physical Adversarial Examples:

- Stickers on stop signs fooling autonomous vehicles
- Glasses that fool facial recognition
- Audio perturbations fooling speech recognition

Defense Mechanisms:

- **Adversarial training**: Train on adversarial examples
- **Input validation**: Detect and reject unusual inputs
- **Ensemble methods**: Multiple models with different vulnerabilities
- **Defensive distillation**: Training technique that smooths decision boundaries
- **Certified defenses**: Mathematical guarantees of robustness (limited applicability)

Development Phase Actions:

- Generate adversarial examples

Narahari

- Train on adversarial data
- Test robustness extensively
- Implement input validation
- Monitor for evasion attempts

---

8. ADDITIONAL DEVELOPMENT CONCEPTS

8.1 Challenger Models

Definition: Alternative models developed alongside primary model to provide comparison and validation

Purpose:

- **Benchmark performance**: Compare primary model against alternatives
- **Detect model drift**: If primary model performance approaches challenger, may need retraining
- **Validation**: Ensure primary model truly performs best
- **Risk management**: Have backup if primary model fails

Types:

- **Simple baseline**: Basic model (e.g., logistic regression) as minimum performance bar
- **Previous version**: Compare new model against predecessor
- **Alternative approach**: Different model type or methodology
- **Human benchmark**: Compare against human expert performance

Use in Monitoring:

- Run challenger models on same data
- Compare performance over time
- If primary model's advantage erodes, investigate (may indicate drift)

Governance: Document challenger model strategy; periodic comparison required

---

8.2 Hallucinations in Generative AI

Definition: Generative AI (especially LLMs) producing false information confidently

Characteristics:

- Generated content appears plausible
- Factually incorrect or nonsensical
- Model doesn't "know" it's wrong

Narahari

- Can include fabricated citations, data, or facts

Causes:

- Probabilistic nature (predicting likely next token, not truth)
- Training data contains errors
- Model extrapolates beyond training data
- No grounding in real-world knowledge

Risks:

- Misinformation spread
- Incorrect decision-making based on false outputs
- Erosion of trust
- Legal liability

Mitigation Strategies:

- **Retrieval-Augmented Generation (RAG)**: Ground generation in retrieved documents
- **Human review**: Verify generated content
- **Confidence scoring**: Identify low-confidence outputs
- **User warnings**: Clearly communicate limitations
- **Fact-checking**: Validate against authoritative sources
- **Fine-tuning**: Train on high-quality, verified data

Governance:

- Disclosure of hallucination risk
- Appropriate use cases (avoid high-stakes decisions based solely on generated content)
- Human oversight requirements
- Testing for hallucination frequency

8.3 Pre-Deployment Pilot Testing

Purpose: Test AI in realistic conditions before full deployment

Pilot Characteristics:

- **Limited scope**: Small user group or geographic area
- **Controlled environment**: Enhanced monitoring and support
- **Reversible**: Can halt if issues arise
- **Realistic**: Actual use conditions, not lab testing

Narahari

Pilot Activities:

- Monitor performance metrics
- Gather user feedback
- Identify usability issues
- Detect unexpected behaviors
- Validate operational procedures
- Test incident response

Success Criteria:

- Performance meets thresholds
- No critical issues
- User acceptance
- Operational feasibility
- Risk mitigation effectiveness

Decision Point: Based on pilot results, decide to:

- Proceed with full deployment
- Iterate and re-pilot
- Abandon deployment

Governance: Pilot testing required for high-risk AI before broad deployment

---

9. DOCUMENTATION REQUIREMENTS

9.1 Technical Documentation

Purpose: Enable understanding, maintenance, and auditing of AI systems

Contents:

System Overview:

- Purpose and use case
- Architecture and components
- Data flow and processing
- Integration points

Model Documentation:

- Model type and architecture
- Training methodology

Narahari

- Hyperparameters
- Performance metrics

Data Documentation:

- Data sources and characteristics
- Preprocessing and transformations
- Feature engineering
- Data quality assessments

Testing and Validation:

- Test methodologies and results
- Performance across subgroups
- Known limitations and edge cases
- Validation evidence

Operational Information:

- Deployment requirements
- Monitoring and maintenance
- Update procedures
- Troubleshooting guides

9.2 Model Cards (Detailed)

Comprehensive Template:

Section 1: Model Details

- Model name and version
- Model type and architecture
- Owner and developer
- Date trained/updated
- License and citation

Section 2: Intended Use

- Primary intended uses
- Intended users
- Out-of-scope uses
- Deployment context

Narahari

Section 3: Factors

- Relevant demographic factors
- Environmental factors
- Technical factors
- Evaluation considerations

Section 4: Metrics

- Performance metrics used
- Why chosen
- How measured
- Decision thresholds

Section 5: Training Data

- Datasets used
- Preprocessing
- Data characteristics
- Known limitations

Section 6: Evaluation Data

- Test datasets
- How evaluated
- Differences from training data

Section 7: Quantitative Analyses

- Overall performance
- Performance by subgroups
- Intersectional analysis
- Error analysis

Section 8: Ethical Considerations

- Known biases
- Potential harms
- Fairness considerations
- Privacy implications

Section 9: Caveats and Recommendations

- Known limitations

Narahari

- When not to use
- Recommended human oversight
- Update schedule

9.3 Governance Documentation

Policy Compliance:

- Which policies apply
- Compliance evidence
- Approvals obtained
- Review schedule

Impact Assessments:

- AIA, DPIA, or other assessments
- Findings and mitigations
- Stakeholder consultation

Risk Assessment:

- Identified risks
- Risk scores
- Mitigation strategies
- Residual risks accepted

Approvals and Reviews:

- Who approved what, when
- Ethics committee review
- Executive signoff
- Audit trail

---

10. KEY DEFINITIONS FOR MODULE 4

AI Development Lifecycle: Phases of Plan, Design, Develop, Implement for building AI systems.

Algorithmic Impact Assessment (AIA): Comprehensive evaluation of AI system's potential impacts on individuals and society.

Data Protection Impact Assessment (DPIA): Privacy risk assessment required under GDPR for high-risk processing.

Narahari

Three Lines of Defense: Risk management model with management (1st line), oversight functions (2nd line), and internal audit (3rd line).

Effective Challenge: Second line's ability and responsibility to question and require changes to first line's work.

Risk Mitigation Hierarchy: Avoid, Minimize/Mitigate, Remediate, Offset (in order of preference).

Five V's of Data: Volume, Velocity, Variety, Veracity, Value—characteristics of big data.

Data Lineage: Complete history of data from origin through transformations.

Data Provenance: Origin and custody chain of data.

Feature Engineering: Selecting, creating, and transforming input variables for ML models.

Model Inversion Attack: Reconstructing training data by querying model.

Model Extraction Attack: Creating copy of model by observing inputs and outputs.

Data Poisoning: Manipulating training data to compromise model behavior.

Adversarial Evasion Attack: Small input perturbations causing incorrect predictions.

Challenger Model: Alternative model for comparison and drift detection.

Hallucination: Generative AI producing false information confidently.

Brittleness: AI system's fragility and sensitivity to small changes.

Model Card: Standardized documentation for AI models.

Pilot Testing: Limited-scope testing in realistic conditions before full deployment.

Differential Privacy: Adding calibrated noise to protect individual privacy in datasets.

Federated Learning: Training across decentralized devices without centralizing data.

Overfitting: Model learns training data too well, failing to generalize.

Robustness: Model's ability to maintain performance under variations.

Repeatability: Ability to achieve consistent results across repeated runs.

---

11. STUDY TIPS FOR MODULE 4

Key Concepts to Master:

1. ✅ Understand **four lifecycle phases** (Plan, Design, Develop, Implement) and activities in each
2. ✅ Know **Three Lines of Defense** model and **Effective Challenge** principle
3. ✅ Master **Risk Mitigation Hierarchy** (Avoid, Minimize, Remediate, Offset)
4. ✅ Understand **Five V's of Data** and their AI implications

Narahari

5. ✅ Know **types of testing** (accuracy, robustness, privacy, interpretability, safety, bias, adversarial)
6. ✅ Master **four AI-specific security threats** and defenses
7. ✅ Understand **data governance** (collection, quality, lineage, wrangling)
8. ✅ Know **feature engineering** and governance considerations
9. ✅ Understand **model cards** and what they should contain
10. ✅ Know **impact assessments** (AIA vs. DPIA) and when each required

Common Pitfalls to Avoid:

- ❌ Confusing Three Lines of Defense roles
- ❌ Not understanding difference between data lineage and provenance
- ❌ Mixing up security threat types
- ❌ Forgetting order of Risk Mitigation Hierarchy
- ❌ Not knowing when DPIA is legally required (GDPR Article 35)
- ❌ Confusing different types of drift (data vs. concept vs. model)

Practical Application:

- For each lifecycle phase, list key governance activities
- Design a model card for a hypothetical AI system
- Create testing plan covering all testing types
- Map Three Lines of Defense to organizational roles
- Develop mitigation strategies for each security threat

Memorization Aids:

Four Lifecycle Phases (P-D-D-I):

- **P**lan (context, assessments, stakeholders)
- **D**esign (architecture, model selection, metrics)
- **D**evelop (data governance, training, testing)
- **I**mplement (pilot testing, pre-deployment validation)

Three Lines of Defense:

- **1st Line**: Management/Developers (own and manage risks)
- **2nd Line**: Oversight functions (challenge and guide)
- **3rd Line**: Internal Audit (independent assurance)

Narahari

Risk Mitigation Hierarchy (A-M-R-O):

- **A**void (don't use AI)
- **M**inimize/Mitigate (reduce risks)
- **R**emediate (fix if occurs)
- **O**ffset (compensate)

Five V's of Data (V-V-V-V-V):

- **V**olume (massive amounts)
- **V**elocity (high speed)
- **V**ariety (diverse types)
- **V**eracity (quality/accuracy)
- **V**alue (actionable insights)

AI Security Threats (I-E-P-E):

- Model **I**nversion
- Model **E**xtraction
- Data **P**oisoning
- Adversarial **E**vasion

Testing Types (A-R-P-I-S-B-R-A):

- **A**ccuracy
- **R**obustness/Reliability
- **P**rivacy
- **I**nterpretability
- **S**afety
- **B**ias/Fairness
- **R**epeatability
- **A**dversarial

Narahari